

Acme Corp AI/ML Engineering Policy Manual

Internal Governance Framework for the Development, Deployment, and Operation of AI/ML Systems

Acme Corp — AI Governance Office (Placeholder Company)

2026

Table of Contents

Introduction and How to Use This Manual

This manual establishes Acme Corp's policy framework governing the development, deployment, and operation of artificial intelligence and machine learning (AI/ML) systems, including generative AI systems built on large language models. It applies to all employees, contractors, and vendors who design, build, deploy, or operate AI/ML systems on behalf of Acme Corp, or who use AI/ML tools in the course of their work.

This document is a placeholder template intended to illustrate the structure and substance of a company AI/ML engineering policy. Company name, role titles, specific tools, and escalation contacts should be replaced with your organization's actual details before adoption. Legal, security, and compliance teams should review and formally approve any policy derived from this template before it is treated as binding.

Section 1: Purpose and Scope

1.1 Purpose

This policy exists to ensure that Acme Corp's use of AI/ML technology is safe, secure, compliant with applicable law and regulation, aligned with the company's ethical commitments, and technically sound. AI/ML systems introduce risks that differ meaningfully from traditional software — including data privacy exposure, unpredictable output behavior, potential for bias or unfair outcomes, and novel security attack surfaces such as prompt injection — and this policy is designed to address those risks specifically, in addition to the general engineering and security policies that continue to apply.

1.2 Scope

This policy applies to:

- Any system that uses a machine learning model, including but not limited to large language models, to generate content, make or support a decision, or take an automated action, whether that model is developed internally, fine-tuned from an open-weight base model, or accessed via a third-party API.
- Any use of third-party generative AI tools (chat assistants, coding assistants, AI-powered SaaS products) by employees in the course of company business, whether or not those tools are formally integrated into a company product.
- Any AI/ML system that processes company data, customer data, or employee data, regardless of where that system is hosted.

1.3 Out of Scope

This policy does not govern purely deterministic, rule-based software systems that do not incorporate a trained machine learning model, nor does it govern personal, non-work use of AI tools on personal devices and accounts, though employees are separately bound by the company's general conduct and confidentiality policies in all contexts.

1.4 Policy Hierarchy

Where this policy conflicts with a more specific policy governing a particular regulatory domain (for example, a policy specific to processing health data or financial data), the more specific policy controls for matters within its scope, and this policy applies as a supplementary baseline for all other matters.

Section 2: Definitions

AI/ML System: Any software system incorporating one or more trained machine learning models, including generative models, classifiers, recommendation systems, and predictive models.

Foundation Model: A large-scale pretrained model, typically a large language model or multimodal model, that serves as a base for further adaptation (via prompting, fine-tuning, or retrieval augmentation) rather than being trained from scratch for a single narrow task.

Fine-Tuning: The process of further training a pretrained model's weights on a task- or domain-specific dataset to adapt its behavior.

Retrieval-Augmented Generation (RAG): A system architecture in which a generative model's output is grounded by retrieving relevant content from an external knowledge source at query time.

Model Risk: The potential for adverse outcomes — financial, legal, reputational, or safety-related — arising from a model's incorrect, biased, unsafe, or otherwise flawed output or decision.

Prompt Injection: An attack in which untrusted input, including retrieved content or tool output, is crafted to manipulate an AI system into behavior outside its intended instructions.

Human-in-the-Loop (HITL): A system design in which a human reviews and approves an AI system's proposed output or action before it takes effect, as opposed to fully autonomous operation.

Model Owner: The individual or team formally accountable for a given AI/ML system's ongoing performance, risk posture, and compliance status.

Sensitive Data: Any data classified under Acme Corp's data classification policy as confidential, restricted, or subject to regulatory protection, including personal data, health data, financial data, and trade secrets.

Section 3: Governance Structure and Roles

3.1 AI Governance Office

Acme Corp maintains a cross-functional AI Governance Office, comprising representatives from engineering, legal, security, privacy, and relevant business units, responsible for maintaining this policy, reviewing high-risk AI/ML system proposals, adjudicating policy exceptions, and reporting on the company's AI risk posture to executive leadership.

3.2 Model Owners

Every AI/ML system in production must have a designated Model Owner, accountable for ensuring the system complies with this policy throughout its lifecycle, maintaining current documentation (see Section 6), coordinating required reviews and re-evaluations, and serving as the primary point of contact during an incident involving the system.

3.3 Engineering Teams

Engineering teams building or operating AI/ML systems are responsible for implementing the technical requirements of this policy — including security controls, evaluation practices, and monitoring — and for escalating to the AI Governance Office when a system's risk classification or intended use changes materially from what was originally reviewed.

3.4 Security and Privacy Teams

The security team is responsible for reviewing AI/ML systems for security vulnerabilities specific to AI systems, including prompt injection resistance and tool-access scoping, and for incident response when an AI/ML system is implicated in a security event. The privacy team is responsible for reviewing data flows into and out of AI/ML systems for compliance with data protection obligations and company privacy commitments.

3.5 Legal and Compliance

Legal and compliance functions review AI/ML systems for regulatory compliance relevant to the system's use case and jurisdiction, review vendor and third-party model provider contracts for adequate data protection and liability terms, and advise on intellectual property

considerations relevant to training data, generated content, and third-party model licensing terms.

Section 4: Acceptable Use of AI/ML Tools

4.1 General Principle

Employees may use approved AI/ML tools to support their work, subject to the data handling and disclosure requirements in this section. Use of AI/ML tools does not relieve an employee of responsibility for the accuracy, quality, and appropriateness of any work product they submit or rely upon.

4.2 Approved Tools List

Only AI/ML tools that have completed the company's vendor security and privacy review, and appear on the current Approved Tools List maintained by the AI Governance Office, may be used with company data. Employees seeking to use a tool not on the approved list must submit a request through the standard vendor review process before doing so.

4.3 Data Handling Rules

- **Restricted and confidential data** (as defined under the company data classification policy) may only be submitted to an AI/ML tool that has been explicitly approved for that data classification, and only through approved, enterprise-configured access — not free consumer-tier accounts, which frequently have different data retention and training-use terms than enterprise offerings.
- **Customer data** may not be submitted to any AI/ML tool unless that tool is contractually bound to Acme Corp's data protection terms and the use case has been reviewed by the privacy team.
- **Source code** may only be submitted to AI coding assistants approved for that purpose, respecting any client or open-source license restrictions on the code in question.
- Employees must not attempt to use an AI/ML tool to circumvent data loss prevention controls, access controls, or other security measures.

4.4 Disclosure Requirements

Any customer- or public-facing content substantially generated by an AI/ML tool must be reviewed by a qualified human before publication and must comply with the company's disclosure obligations regarding AI-generated content where applicable law or company policy requires such disclosure. Internal work product does not require disclosure of AI assistance unless a specific business unit's policy requires it, but employees remain fully accountable for the accuracy and appropriateness of any AI-assisted output they submit as their own work.

4.5 Prohibited Uses

The following uses of AI/ML tools are prohibited without explicit, documented approval from the AI Governance Office: use in any decision materially affecting an individual's employment,

credit, insurance, housing, or legal rights without a compliant human review process; use to generate content impersonating a real individual without their consent; use to circumvent security controls, including attempts to extract another user's data through an AI system; and use in any safety-critical system where a model failure could result in physical harm, without the heightened review process defined in Section 9.

Section 5: Data Governance and Privacy

5.1 Data Minimization

AI/ML systems should be designed to process the minimum data necessary to accomplish their intended function. Retrieval systems in particular should be scoped to relevant document sets rather than granted broad access to entire data repositories by default, and access controls on underlying data sources must be respected and enforced at the retrieval layer, not merely at the presentation layer.

5.2 Data Provenance and Consent

Teams building or fine-tuning models must document the provenance of training, fine-tuning, and retrieval-source data, including whether that data was collected with consent appropriate to its intended AI/ML use, and whether any contractual, licensing, or regulatory restrictions apply to its use for model training or as retrieval context. Personal data used in AI/ML systems must have a valid legal basis for that specific use under applicable data protection law.

5.3 Third-Party Model Data Handling

Before sending company or customer data to a third-party model provider's API, teams must confirm and document the provider's data retention policy, whether submitted data is used to train or improve the provider's models (and, if so, whether this has been contractually disabled, as is typically available for enterprise agreements), the provider's data residency and cross-border transfer practices relative to applicable regulatory requirements, and the provider's security certifications and incident history.

5.4 Right to Deletion and Data Subject Requests

Systems that store personal data as part of an AI/ML pipeline — including embedded vector representations, fine-tuning datasets, and conversation logs — must support the ability to locate and delete an individual's data upon a valid deletion request, including from embedding indexes and any fine-tuned model artifacts derived from that data where technically feasible. Teams should be aware that deleting personal data from a fine-tuned model's weights directly is not always straightforward, and should plan data retention and fine-tuning strategies with this constraint in mind.

5.5 Data Retention

AI/ML system logs, including prompts and outputs, must follow the company's data retention schedule appropriate to the sensitivity of the data involved, balancing the legitimate need for

logs to support debugging, evaluation, and incident investigation against the privacy risk of retaining sensitive interaction data longer than necessary.

Section 6: Model Development Standards

6.1 Documentation Requirements

Every AI/ML system must maintain current documentation covering its intended use case and explicitly out-of-scope uses, the underlying model(s) used and their version, key architectural decisions (retrieval sources, fine-tuning approach, agentic tool access), evaluation results and known limitations, and a designated Model Owner. This documentation must be reviewed and updated whenever the system undergoes a material change.

6.2 Development Environment Standards

Development and experimentation with AI/ML systems using real production or customer data must occur in environments meeting the same security and access control standards as production, not in unmanaged personal or ad hoc environments. Synthetic or appropriately anonymized data should be preferred for early-stage experimentation wherever it can adequately support the development work.

6.3 Version Control and Reproducibility

Prompts, prompt templates, fine-tuning datasets, and system configuration must be version-controlled with the same rigor as application code, given that changes to any of these can materially change system behavior. Teams should maintain sufficient records to reconstruct why a given production behavior occurred at a given point in time, including which prompt version, model version, and retrieval configuration was active.

6.4 Code and Configuration Review

Changes to prompts, agentic tool definitions, and model configuration that affect production behavior must go through the same peer review process as application code changes, given that such changes can materially affect system safety and quality despite not always resembling traditional code.

Section 7: Third-Party and Open-Source Model Use

7.1 Vendor Model Providers

Use of a third-party hosted model provider requires a signed data processing agreement appropriate to the data the system will send that provider, review of the provider's security certifications and compliance posture by the security and legal teams, and documentation of the specific model version in use, given that provider-side model updates can change system behavior even without any change on Acme Corp's part.

7.2 Open-Weight Model Use

Teams self-hosting open-weight models must verify the model's license permits the intended commercial use, including any fine-tuning or output-related restrictions some open-weight licenses impose, document the model's provenance and, where available, its training data characteristics, and apply the same security hardening to model-serving infrastructure as any other production service handling sensitive data.

7.3 Third-Party Fine-Tuned or Adapted Models

Models fine-tuned by a third party on Acme Corp's behalf, or adapted from a third-party base model, must be reviewed for the same data handling, license compliance, and evaluation standards as internally developed models before production use, and the resulting model artifacts' ownership and usage rights must be clearly established contractually.

7.4 Provider Change Management

Because third-party model providers may update, deprecate, or change the behavior of hosted models with limited notice, teams relying on third-party models must monitor provider communications for relevant changes, maintain a fallback plan for provider deprecations, and re-run evaluation suites after any provider-side model version change is detected or announced, before assuming continued production suitability.

Section 8: Security Requirements for AI/ML Systems

8.1 Prompt Injection Defense

Any AI/ML system that processes untrusted input — including user-supplied content, retrieved documents, or third-party tool output — must implement documented defenses against prompt injection appropriate to its risk level, including clear delimitation of untrusted content within prompts, least-privilege scoping of any tools or actions the system can take as a result of processing that content, and application-layer validation of any action the model proposes before it is executed, rather than relying on the model's own judgment as the sole safeguard.

8.2 Tool and Agent Permission Scoping

Agentic systems with tool access must be granted the minimum permissions necessary for their intended function. High-consequence actions — financial transactions, data deletion, external communications sent on the company's behalf, and changes to access control settings — require human-in-the-loop approval and may not be granted to a fully autonomous agent without explicit, documented AI Governance Office approval.

8.3 Credential and Secret Management

Credentials used by AI/ML systems to access tools, APIs, or data sources must follow the company's standard secrets management practices, must not be embedded in prompts, code, or

configuration files in plaintext, and must be scoped as narrowly as possible to the specific resources the system requires.

8.4 Model and Data Access Logging

AI/ML systems must log sufficient detail to support security investigation, including which data sources were accessed for a given request, which tools were invoked and with what arguments, and, subject to the data retention and privacy requirements in Section 5, the prompts and outputs involved in security-relevant events.

8.5 Adversarial Testing

AI/ML systems classified as medium or high risk under Section 9 must undergo adversarial testing (sometimes called red-teaming) prior to production deployment and periodically thereafter, specifically probing for prompt injection susceptibility, jailbreak resistance, and unauthorized tool-use scenarios, in addition to standard security testing applied to any production system.

Section 9: Model Risk Management and Risk Classification

9.1 Risk Tiers

Every AI/ML system must be classified into one of three risk tiers at initial design and re-assessed whenever its use case materially changes:

- **Tier 1 — Low Risk:** Internal productivity tools with no customer-facing output, no access to sensitive data, and no ability to take automated actions with real-world effect. Requires standard documentation and lightweight review.
- **Tier 2 — Medium Risk:** Customer-facing systems generating content reviewed by a human before publication, or internal systems with access to sensitive data but no autonomous high-consequence actions. Requires full documentation, evaluation against a golden test set, and AI Governance Office review prior to launch.
- **Tier 3 — High Risk:** Systems that materially affect an individual's access to services, employment, credit, or legal rights; systems with autonomous ability to take high-consequence actions; or systems operating in safety-critical contexts. Requires the full review process in this section, executive sign-off, ongoing monitoring, and periodic re-certification.

9.2 Risk Assessment Factors

Risk classification should account for the potential severity of a failure (ranging from minor inconvenience to significant financial, legal, or physical harm), the population affected and whether that population includes vulnerable individuals, the degree of human oversight built into the system (fully autonomous versus human-in-the-loop versus human-reviewed-before-effect), and the reversibility of any action the system can take.

9.3 Pre-Launch Review

Tier 2 and Tier 3 systems must complete a pre-launch review with the AI Governance Office before production deployment, covering the system's documented intended use and limitations, evaluation results against an appropriate golden test set, security review findings including adversarial testing results for Tier 3 systems, privacy and data handling review, and a defined incident response and rollback plan.

9.4 Ongoing Risk Monitoring

Risk classification is not a one-time determination. Model Owners must monitor for changes that would warrant re-classification, including expansion of the system's intended use case, integration of new tools or data access, and observed production incidents suggesting the system's real-world risk profile differs from its initial assessment.

Section 10: Testing, Validation, and Evaluation

10.1 Evaluation Prior to Launch

Every AI/ML system must be evaluated against a documented test set representative of its intended production use before launch, covering both typical-case performance and known edge cases relevant to the system's function. Tier 2 and Tier 3 systems must additionally document the specific quality, safety, and fairness metrics used and the thresholds required for launch approval.

10.2 Ongoing Evaluation

Production AI/ML systems must be re-evaluated against their golden test set whenever the underlying model, prompt, or retrieval configuration changes materially, and on a periodic basis regardless of explicit changes, to detect drift in third-party model provider behavior or in the characteristics of production traffic relative to the original test set.

10.3 Bias and Fairness Testing

Tier 2 and Tier 3 systems whose output could plausibly vary in quality or outcome across demographic groups must include subgroup evaluation as part of their test methodology, and any material disparity identified must be documented, escalated to the AI Governance Office, and remediated or explicitly risk-accepted with appropriate sign-off before launch.

10.4 User Feedback Integration

Production systems should provide a mechanism for end users to flag incorrect, inappropriate, or unsafe output, and Model Owners must review flagged feedback on a regular cadence, incorporate confirmed failure cases into the system's ongoing evaluation set, and escalate patterns suggesting a systemic issue rather than isolated errors.

Section 11: Deployment Approval Process

11.1 Approval Requirements by Tier

Tier 1 systems require sign-off from the Model Owner's engineering manager. Tier 2 systems require sign-off from the Model Owner, the relevant engineering manager, and a designated AI Governance Office reviewer. Tier 3 systems require the above plus executive sponsor sign-off and a documented AI Governance Office committee review.

11.2 Change Management for Production Systems

Material changes to a production AI/ML system — a new model version, a materially revised prompt, expanded tool access, or a new data source — require re-review proportional to the system's risk tier and the materiality of the change, following the same change management discipline the company applies to other production systems, with the addition of the AI/ML-specific evaluation and security checks defined elsewhere in this policy.

11.3 Staged Rollout

Tier 2 and Tier 3 systems should be deployed via staged rollout (canary or percentage-based rollout) rather than an immediate full release, with defined success criteria and monitoring at each stage before proceeding, and a documented rollback plan that can be executed quickly if monitoring reveals a problem.

Section 12: Monitoring and Incident Response

12.1 Production Monitoring Requirements

All production AI/ML systems must be monitored for operational health (latency, error rate, cost), output quality signals (sampled evaluation, user feedback trends), and safety signals (rate of flagged or moderated content, anomalous tool-use patterns). Tier 3 systems require real-time alerting on safety-relevant signals, not only periodic review.

12.2 Incident Classification

An AI/ML incident is any event in which a system produced materially incorrect, unsafe, biased, or policy-violating output, took an unauthorized or erroneous automated action, or was implicated in a data privacy or security event. Incidents are classified by severity consistent with the company's general incident response framework, with the addition of AI-specific severity factors such as whether the incident affected a Tier 3 system or involved sensitive data exposure.

12.3 Incident Response Process

Upon detecting a suspected AI/ML incident, the Model Owner must be notified immediately, the system should be assessed for whether immediate mitigation (rollback, disabling a specific capability, or taking the system offline) is warranted given the severity, the AI Governance

Office and, where applicable, security, privacy, and legal teams must be looped in proportional to severity, and a post-incident review must be conducted to identify root cause and remediation, following the same rigor as the company's general incident postmortem process.

12.4 Post-Incident Follow-Through

Findings from AI/ML incidents must be incorporated into the affected system's evaluation set to prevent regression, and patterns observed across multiple incidents or systems should be escalated to the AI Governance Office as potential input to company-wide policy or tooling improvements.

Section 13: Intellectual Property and Copyright

13.1 Training and Fine-Tuning Data Rights

Teams must confirm they hold appropriate rights to use any dataset for model training or fine-tuning, including verifying license terms for third-party or open datasets, and obtaining appropriate rights or consent for any proprietary or customer-derived data used for this purpose.

13.2 Output Ownership and Third-Party IP Risk

Employees using AI/ML tools to generate content for company work product should be aware that generated output can, in some circumstances, closely resemble copyrighted material the underlying model was trained on, and should apply the same diligence to AI-generated content intended for external use — particularly code, marketing copy, and other publishable material — as they would to any third-party sourced content, including review against the company's standard IP clearance process for external-facing deliverables.

13.3 Attribution and Licensing of Open-Weight Models

Use of open-weight models and associated tooling must comply with the applicable open-source or model license terms, including any attribution, share-alike, or field-of-use restrictions, and the legal team should be consulted when a license's terms are ambiguous as applied to a specific intended use.

Section 14: Compliance and Regulatory Alignment

14.1 Jurisdictional Awareness

AI/ML systems that operate across multiple jurisdictions must account for the applicable regulatory requirements in each jurisdiction where the system is used or where affected individuals are located, recognizing that AI-specific regulation varies significantly by region and continues to evolve. The legal and compliance team maintains current guidance on applicable requirements and should be consulted early in the design of any system with cross-border reach.

14.2 Sector-Specific Compliance

Systems operating in regulated domains — financial services, healthcare, employment, and others — must additionally comply with the sector-specific regulatory requirements applicable to that domain, which may impose requirements beyond this general policy, including specific explainability, audit trail, or human-review obligations.

14.3 Audit Readiness

Tier 2 and Tier 3 systems must maintain documentation and logs sufficient to support a regulatory or internal audit of the system's decision-making process, data handling, and risk management practices, and Model Owners are responsible for ensuring this documentation remains current and readily producible on request.

Section 15: Training, Enforcement, and Policy Review

15.1 Employee Training

All employees who develop, deploy, or make substantial use of AI/ML systems as part of their role must complete AI governance training appropriate to their role, covering the acceptable use requirements in Section 4 at minimum, with additional role-specific training for Model Owners and engineers building Tier 2 and Tier 3 systems.

15.2 Enforcement

Violations of this policy will be addressed through the company's standard conduct and performance management processes, with severity of response proportional to the violation's actual or potential impact. Employees who identify a potential policy gap or violation are encouraged to report it to the AI Governance Office without fear of retaliation.

15.3 Exceptions

Exceptions to this policy may be granted only by the AI Governance Office, must be documented with a clear business justification and a defined expiration or review date, and must include any compensating controls put in place to manage the risk the policy provision was designed to address.

15.4 Policy Review Cadence

This policy will be formally reviewed at least annually, and on an ad hoc basis when a material change in regulation, technology, or company risk appetite warrants earlier review. The AI Governance Office owns this review process and is responsible for communicating material changes to affected teams.

15.5 Document Control

This is a living document. Version history, review dates, and approval records should be maintained in the company's policy management system rather than in this document itself,

and employees should always refer to the current published version rather than a locally saved copy.